UNIVERSIDAD INTERNACIONAL DEL ECUADOR

FUNDAMENTOS DE LA SEGURIDAD DE LOS SISTEMAS INFORMÁTICOS Y DE LA INFORMACIÓN

Proyecto Integrador – Fase 2: Diseño de seguridad

Integrantes

Santiago Alejandro Lucina Mena

Pamela Stefania Toapanta Pila

Camila Isabel Paucar Guaranda

Profesor:

JUAN FERNANDO LOPEZ TITO

3 de noviembre de 2026

ÍNDICE

1. BREVE REFERENCIA A LA SOLUCIÓN DESARROLLADA 2
2. REVISIÓN DE REQUISITOS DE SEGURIDAD 3
3. DISEÑO DEL PROCESO DE AUTENTICACIÓN 5
4. DISEÑO DE AUTORIZACIÓN Y CONTROL DE ACCESO 7
5. PROTECCIÓN DE CREDENCIALES E INFORMACIÓN 10
6. DISEÑO DE CONTROLES DE SEGURIDAD 12
7. CONTROLES DE SEGURIDAD PROPUESTOS 16
8. PLAN DE PRUEBAS DE SEGURIDAD 18
9. MATRIZ DE TRAZABILIDAD ACTUALIZADA 19
NOMBRES Y FIRMAS 20

1. BREVE REFERENCIA A LA SOLUCIÓN DESARROLLADA

La solución corresponde a una plataforma corporativa de correos internos centralizar la comunicación entre las dos sedes operativas de la organización, sustituyendo canales informales y mitigando riesgos de fuga de información confidencial. El sistema integra los siguientes componentes esenciales:

- **Aplicaciones y Servicios:**
  - **Servidor Central de Correo (Backend en Go):** Gestiona de forma concurrente la recepción, procesamiento, almacenamiento y entrega de mensajes entre ambas sedes.
  - **Cliente de Correo en Go:** Interfaz instalada en las estaciones de trabajo locales para la redacción, consulta y gestión de bandejas de usuario.
  - **Servicio de Autenticación Centralizada (FastAPI):** Módulo independiente responsable de validar credenciales, emitir tokens de sesión temporal y aplicar controles contra accesos no autorizados.
  - **Base de Datos Relacional:** Almacén persistente de la correspondencia, metadatos de transacciones y registros de auditoría operativa.
- **Infraestructura de Conectividad y Seguridad Perimetral:**
  - **Routers de Borde OpenWrt:** Encargados del enrutamiento dinámico entre sedes (OSPF) a través de un enlace WAN inter-sede, gobernando el tráfico perimetral mediante políticas de firewall.
  - **Switches Cisco de Distribución y Acceso:** Dispositivos de conmutación configurados para segmentar el tráfico en VLANs aisladas, garantizando alta disponibilidad y aislamiento del plano de gestión.

2. REVISIÓN DE REQUISITOS DE SEGURIDAD

A partir del análisis de riesgos de la Fase 1 y de la retroalimentación brindada por el docente, se ajustaron los requisitos de seguridad para que cuenten con criterios de aceptación claros y fáciles de verificar. A partir de eso, se definieron las siguientes áreas clave: inicio de sesión seguro, control de acceso según el rol de cada usuario, protección

de los datos tanto al guardarse como al enviarse por la red, y aislamiento del tráfico de administración de los equipos.

Tabla 1

Requisitos de seguridad y criterios de aceptación ajustados

CÓDIGO	REQUISITO AJUSTADO	CRITERIO DE ACEPTACIÓN
RF-SEC-01	El sistema deberá exigir autenticación individual mediante usuario y contraseña en el servicio FastAPI, implementando políticas de contraseñas seguras, control de sesiones simultáneas y un límite máximo de intentos fallidos consecutivos (máximo 3 intentos) con bloqueo temporal. Además, emitirá un token con tiempo de expiración definido y cerrará la sesión por inactividad en el cliente Go.	Un usuario con credenciales correctas recibe un token temporal y accede a la plataforma. Si ingresa datos erróneos menos de 3 veces, el sistema deniega el acceso y permite reintentar. Al tercer intento fallido consecutivo, la cuenta o la petición queda bloqueada temporalmente y se registra el evento en auditoría. No se permiten contraseñas débiles ni sesiones duplicadas. Si el token expira o pasan 10 minutos de inactividad, se exige reautenticación.
RF-SEC-02	El servidor de correo en Go deberá validar el rol del usuario y su identidad en cada petición para permitir el acceso únicamente a su propio buzón y a las funciones de su área.	Un usuario autenticado solo puede leer, enviar o eliminar mensajes de su propia bandeja; cualquier intento de consultar o alterar correos de otros colaboradores o acceder a funciones de administración es bloqueado por el servidor.
RF-SEC-03A	El sistema deberá proteger las contraseñas de los usuarios almacenándolas de forma segura mediante funciones hash en la base de datos, garantizando que nunca se guarden en texto plano.	Ninguna contraseña es legible en la base de datos; ante una consulta directa a las tablas de usuarios, únicamente se visualizan cadenas cifradas mediante hash irreversible.
RF-SEC-03B	El sistema deberá cifrar las comunicaciones y el tráfico de mensajes, credenciales y	Al realizar una captura de tráfico en la red o en el enlace inter-sede, el contenido de los mensajes, tokens y

	tokens entre el cliente Go, el servidor Go y FastAPI mediante canales seguros.	credenciales resulta ilegible para terceros; las conexiones que no utilicen el canal cifrado son rechazadas.
RF-SEC-04	Los routers OpenWrt y switches Cisco deberán restringir el acceso administrativo exclusivamente a la VLAN 99 mediante reglas de firewall y listas de control de acceso (ACL), además de autenticar el enrutamiento OSPF entre sedes.	Un administrador desde la VLAN 99 con credenciales válidas puede gestionar los equipos; cualquier intento de acceso administrativo desde las redes de usuarios, servidores o invitados, o anuncios OSPF sin autenticar, son bloqueados.

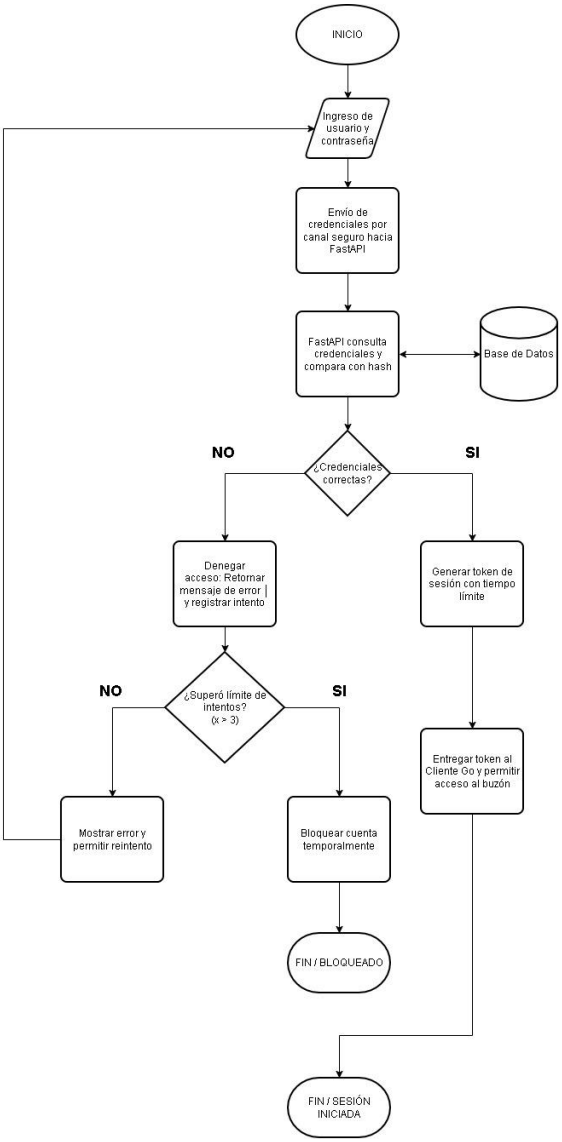
Nota. Elaboración propia (2026).

3. DISEÑO DEL PROCESO DE AUTENTICACIÓN

El proceso de autenticación es un factor muy importante dentro del sistema de correos debido a que permite comprobar la identidad de cada persona antes de que pueda utilizar la plataforma. El flujo inicia cuando el usuario realiza el ingreso de sus credenciales, las cuales pasan por un proceso de validación técnica que determina el resultado de la autenticación, permitiendo finalmente el acceso o aplicando el rechazo de la solicitud, integrando además controles preventivos contra ataques de fuerza bruta.

Figura 1

Diagrama de flujo del proceso de autenticación del sistema de correo interno



Nota. Elaboración propia (2026).

Descripción del Flujo y Componentes del Diseño:

- **Información que utilizará el usuario para autenticarse:** El usuario ingresará a través de la interfaz del cliente en Go con su identificador institucional único y su contraseña personal. Esta información se envía de forma protegida hacia el servicio de autenticación en FastAPI para su comprobación.

- **Qué ocurrirá cuando las credenciales sean correctas:** FastAPI consulta el registro del usuario en la base de datos y compara la contraseña suministrada contra el hash criptográfico almacenado. Al verificarse la coincidencia:
    - El sistema reinicia el contador de intentos fallidos.
    - FastAPI genera un token de sesión digital temporal con tiempo límite de duración.
    - La aplicación cliente en Go recibe este token y habilita el acceso al usuario para su buzón de correo
- **Qué ocurrirá cuando las credenciales sean incorrectas:** Si el identificador no existe o la contraseña no coincide con el hash:
    - FastAPI rechaza la solicitud sin emitir ningún token de sesión y genera un registro de auditoría con la hora y la IP del intento fallido.
    - Se evalúa el número de intentos consecutivos erróneos:
        - **Si los intentos son menores a 3:** El sistema muestra una alerta genérica en la interfaz indicando credenciales inválidas y permite al usuario reintentar el ingreso.
        - **Si supera el límite permitido (más de 3 intentos consecutivos):** El sistema aplica un bloqueo temporal a la cuenta, denegando nuevos intentos de inicio de sesión durante un lapso determinado para mitigar ataques automatizados de adivinación de contraseñas.
- **Recursos que requerirán una autenticación válida:** La totalidad de los servicios y operaciones internas de la plataforma demandan un token activo emitido por FastAPI, incluyendo:
    - Consulta y lectura de mensajes en las bandejas de entrada y salida.
    - Redacción, adjuntos y envío de nuevos mensajes inter-sede.
    - Cambio de estados de los correos (leído, no leído) y eliminación de estos
    - Módulos de administración técnica de la plataforma.

El único recurso accesible sin previa autenticación es la vista inicial de inicio de sesión del cliente.

4. DISEÑO DE AUTORIZACIÓN Y CONTROL DE ACCESO

Una vez que un usuario ha superado con éxito el proceso de autenticación, el sistema debe determinar con precisión a qué opciones, datos y servicios puede acceder.

Tipos de Usuarios y Roles Definidos

Tomando como base la estructura operativa de las sedes y los actores identificados en el sistema, se establecen tres roles principales:

1. **Usuario Operativo (Ventas / Operaciones):** Personal encargado del flujo de trabajo diario. Su función primordial es generar y enviar correspondencia institucional y dar seguimiento a sus solicitudes emitidas.
2. **Usuario Administrativo (Gestión / Recepción):** Personal responsable del trámite y gestion de normas corporativas. Se enfoca en revisar la correspondencia recibida, actualizar los estados de lectura y depurar registros mediante borrado lógico.
3. **Supervisor Técnico (Sistemas / TI):** Personal especializado en la administración y monitoreo de la plataforma y de los equipos de red. No interviene en la correspondencia privada de los empleados, pero gestiona la operatividad técnica del entorno.

Matriz de Control de Acceso Basada en Roles

En la Tabla 2 se detalla la matriz de autorización, especificando los recursos disponibles, las acciones que cada rol tiene permitidas y las restricciones impuestas por el sistema:

Tabla 2

Matriz de autorización y control de acceso por roles

USUARIO / ROL	RECURSO O FUNCIONALIDAD	ACCESO PERMITIDO	RESTRICCIÓN

USUARIO OPERATIVO	Redacción y envío de mensajes. Consulta de bandeja de salida propia.	Redactar y enviar correos hacia cualquier sede. Listar y revisar únicamente los mensajes enviados por su cuenta.	Prohibido leer, abrir o listar bandejas de entrada de otros usuarios o áreas. Prohibido eliminar correos o alterar registros de la base de datos. Sin acceso a opciones de administración o red.
USUARIO ADMINISTRATIVO	Consulta de bandeja de entrada propia. Lectura y actualización de estado. Eliminación lógica.	Ver mensajes dirigidos a su buzón. Abrir mensajes y marcar automáticamente como *leído*. Aplicar borrado lógico a correos de su bandeja.	Prohibido redactar o enviar correos en nombre de otros usuarios. Prohibido consultar bandejas de salida o borradores ajenos. Prohibido modificar configuraciones del servidor o de red.
SUPERVISOR TÉCNICO	Métricas del sistema y auditoría. Validación y revocación de tokens. Gestión de routers y switches.	Monitorear la conectividad inter-sede y el servicio FastAPI. Inspeccionar registros de auditoría (logs de conexión, intentos fallidos).	Prohibido abrir, leer o modificar el contenido y cuerpo de los correos personales de los colaboradores. No utiliza el sistema como remitente o destinatario de

		Administrar dispositivos de red desde la VLAN 99.	mensajería operativa.

Nota. Elaboración propia (2026).

5. PROTECCIÓN DE CREDENCIALES E INFORMACIÓN

La plataforma maneja información con distintos niveles de sensibilidad. Por eso cada dato recibe un mecanismo distinto según la necesidad de recuperarlo: lo que solo debe verificarse se protege con técnicas irreversibles, y lo que debe volver a leerse se protege con cifrado reversible controlado.

5.1. Protección de contraseñas almacenadas

Las contraseñas nunca se guardan en texto plano ni con cifrado reversible. El servicio FastAPI las procesa con una función hash adaptativa combinada con una sal aleatoria única por usuario. En el login, FastAPI calcula el hash de la contraseña ingresada y lo compara con el almacenado, así que el sistema nunca necesita conocer la contraseña original. La sal evita que dos usuarios con la misma contraseña tengan el mismo hash y vuelve inútiles las rainbow tables. El costo computacional del algoritmo encarece los ataques de fuerza bruta si la base de datos se filtra. Si un usuario olvida su contraseña, se restablece, no se recupera.

5.2. Clasificación de la información y mecanismo aplicado

Tabla 3

Información sensible, nivel de protección y mecanismo de seguridad

INFORMACIÓN	¿POR QUÉ ES SENSIBLE?	PROTECCIÓN APLICADA	PRINCIPIO DE SEGURIDAD
CONTRASEÑAS DE USUARIOS	Su exposición permite	Hash (bcrypt/Argon2) en reposo; TLS en	Confidencialidad; mínimo privilegio

	suplantar identidades	tránsito. **No es reversible**	(ni el administrador puede leerlas)
TOKENS DE SESIÓN (JWT)	Quien los captura se hace pasar por el usuario sin conocer su clave	Firma digital, expiración corta, revocación por sesión única, TLS 1.3, purga en memoria del cliente	Integridad y autenticidad; limitación temporal
CUERPO Y METADATOS DE LOS CORREOS	Contienen instrucciones directivas y administrativas	TLS 1.3 en tránsito; cifrado simétrico (AES-256-GCM) en reposo; acceso solo del propietario del buzón	Confidencialidad e integridad; defensa en profundidad
CREDENCIALES DE ADMINISTRACIÓN DE RED	Dan control total sobre routers y switches	Acceso solo desde VLAN 99, hashes en los equipos, autenticación OSPF, no almacenarlas en el repositorio ni en el código	Segregación; mínimo privilegio
CLAVES Y SECRETOS DEL SISTEMA (CLAVE DE FIRMA JWT, CLAVES DE	Su robo anula los demás controles	Variables de entorno o archivo protegido fuera del repositorio, permisos	Separación de claves y datos; mínimo privilegio

CIFRADO, CONEXIÓN A BD)		restringidos, rotación periódica	
REGISTROS DE AUDITORÍA	Evidencian intentos fallidos, IP y horarios; su alteración oculta ataques	Acceso de solo lectura para el Supervisor Técnico, no contienen contraseñas ni tokens completos	Trazabilidad; no repudio

Nota. Elaboración propia (2026).

5.3. Justificación del cifrado reversible

Solo se usa cifrado reversible en los mensajes (cuerpo y metadatos) almacenados en la base de datos. Se justifica porque el destinatario debe poder leerlos cuando quiera, así que el sistema tiene que recuperarlos en texto claro. Las contraseñas y los tokens no tienen esta necesidad, por eso no se les aplica cifrado reversible. La clave de cifrado se guarda separada de la base de datos para que un volcado de la BD, por sí solo, no exponga los mensajes.

6. DISEÑO DE CONTROLES DE SEGURIDAD

Los controles responden a los riesgos de la Fase 1 y a los requisitos de la sección 1. Siguiendo la retroalimentación, se separan los mecanismos de protección de contraseñas (C-05) y de comunicaciones (C-06), y el riesgo R0-2 se desglosa en subriesgos para que cada vulnerabilidad tenga su control.

Tabla 4

Controles de seguridad diseñados

CÓDIGO	CONTROL	RIESGO / REQUISITO	QUÉ PROTEGE	CÓMO FUNCIONA	DÓNDE SE APLICA

C-01	Política de contraseñas robustas	R0-2A (contraseñas predecibles) / RF-SEC-01	Cuentas de usuario	Longitud mínima de 10 caracteres con mayúscula, minúscula, número y símbolo; rechaza contraseñas comunes, secuencias o derivadas del nombre de usuario	Registro y cambio de contraseña en FastAPI
C-02	Sesión única y cierre por inactividad	R0-2B (credenciales compartidas y sesiones abandonadas) / RF-SEC-01	Sesiones y buzones	Cada login genera un identificador de sesión único y revoca el anterior; el cliente cierra la sesión tras 10 min de inactividad y borra el token de memoria	FastAPI (emisión y revocación) y cliente Go (temporizador)
C-03	Bloqueo por intentos fallidos	R0-2A (adivinación de contraseñas) / RF-SEC-01	Cuentas y servicio de autenticación	Contador por usuario e IP; al 3.er intento consecutivo fallido bloquea la cuenta 15 min y registra el evento; el contador se reinicia con un login correcto	FastAPI

C-04	RBAC y validación de propiedad del buzón	R0-2C (acceso indebido a bandejas ajenas) / RF-SEC-02	Correos y funciones administrativas	En cada petición el servidor Go valida el token, el rol y que el recurso pertenezca al usuario del token; si no, responde 403	Backend Go (middleware en cada endpoint)
C-05	Hash seguro de contraseñas	R0-2D (fuga de credenciales por filtración de BD) / RF-SEC-03A	Contraseñas almacenadas	bcrypt/Argon2 con sal aleatoria por usuario; solo se guarda el hash	FastAPI y base de datos
C-06	Cifrado en tránsito con TLS 1.3	R0-1 (interceptación y alteración) / RF-SEC-03B	Tokens, credenciales y mensajes en la red	Todos los canales cliente Go - servidor Go - FastAPI exigen TLS 1.3 con certificados válidos; se rechaza tráfico HTTP sin cifrar	Comunicaciones entre componentes y enlace inter-sede
C-07	Aislamiento del plano de gestión y OSPF autenticado	R0-3 (compromiso de administración de red) / RF-SEC-04	Routers OpenWrt y switches Cisco	ACLs y reglas de firewall que permiten SSH/HTTPS administrativo solo desde la VLAN 99; autenticación criptográfica en vecinos OSPF	Routers, switches y enlace OSPF

C-08	Gestión segura de tokens	R0-1 y R0-2B (robo y reutilización de tokens) / RF-SEC-01	Tokens de sesión	(preferible HMAC-SHA sobre MD5) Tokens JWT firmados con clave secreta, con expiración corta y verificación de firma y vigencia en cada petición; la lista de sesiones revocadas se consulta al validar	FastAPI (emisión) y servidor Go (validación)
C-09	Registro de auditoría	R0-2 y R0-3 (detección y trazabilidad) / RF-SEC-01, RF-SEC-04	Evidencia de incidentes	Registra fecha, usuario, IP y resultado de logins, bloqueos, revocaciones y accesos denegados, sin guardar contraseñas ni tokens completos; solo lectura para el Supervisor Técnico	FastAPI, servidor Go y equipos de red
C-10	Cifrado en reposo de mensajes y gestión de secretos	Fuga de información por acceso a la BD o al servidor / RF-SEC-02	Cuerpo y metadatos de mensajes; claves	Mensajes cifrados con AES-256-GCM antes de guardarse; las claves se mantienen	Servidor Go, base de datos y se

	fuera del repositorio y de la BD, con permisos restringidos

Nota. Elaboración propia (2026).

7. CONTROLES DE SEGURIDAD PROPUESTOS

C-01: Política de contraseñas robustas y validación en registro/cambio:

- **Mecanismo:** El servicio de autenticación en FastAPI valida que toda contraseña cumpla con una longitud mínima de 10 caracteres, incluyendo al menos una letra mayúscula, una minúscula, un número y un carácter especial.
- **Restricción adicional:** Se rechazan patrones comunes o triviales (nombres de usuario, secuencias numéricas o palabras del diccionario).

C-02: Control de concurrencia y bloqueo por inactividad:

- **Mecanismo:** Emisión de un identificador de sesión único asociado al token JWT. Si se detecta un nuevo inicio de sesión válido con la misma cuenta, el token previo queda revocado automáticamente, impidiendo el uso simultáneo de una sola cuenta entre múltiples colaboradores.
- **Expiración:** El cliente en Go implementa un temporizador de inactividad de 10 minutos que limpia las credenciales en memoria y fuerza la reautenticación.

C-03: Umbral de intentos fallidos con bloqueo temporal:

- **Mecanismo:** FastAPI mantiene un contador de intentos fallidos por usuario e IP. Tras 3 intentos consecutivos erróneos, la cuenta se bloquea por 15 minutos y se emite una alerta en los registros de auditoría.

C-04: Control de acceso basado en roles y validación de propiedad:

- **Mecanismo:** El backend en Go valida en cada petición HTTP el token y comprueba que el remitente o solicitante coincida estrictamente con el ID del usuario en el token, impidiendo la lectura, envío o borrado de mensajes de buzones ajenos.

C-05: Almacenamiento criptográfico seguro de contraseñas:

- **Mecanismo:** Las contraseñas se procesan exclusivamente en FastAPI utilizando el algoritmo bcrypt o Argon2 con sal aleatoria por usuario antes de almacenarse en la base de datos, garantizando que nunca se persistan en texto plano.

C-06: Cifrado en tránsito de capa de transporte:

- **Mecanismo:** Configuración obligatoria de TLS 1.3 en los canales de comunicación entre el cliente Go, el servidor Go y FastAPI, cifrando la transmisión de mensajes, contraseñas y tokens, y rechazando tráfico sin cifrar.

C-07: Aislamiento del plano de gestión y autenticación de enrutamiento:

- **Mecanismo:** Los routers OpenWrt y switches Cisco restringen el tráfico administrativo SSH/HTTPS exclusivamente a la VLAN 99 mediante ACLs y

reglas de firewall perimetral, complementado con autenticación criptográfica MD5/SHA en las adyacencias OSPF entre sedes.

8. PLAN DE PRUEBAS DE SEGURIDAD

Tabla 5

Plan de pruebas de seguridad del sistema de correo interno

PRUEBA	REQUISITO / CONTROL	ACCIÓN A REALIZAR	RESULTADO ESPERADO
PS-01	RF-SEC-01 / C-01, C-03 (Credenciales inválidas y fuerza bruta)	Ingresar deliberadamente una contraseña incorrecta 3 veces consecutivas para un mismo usuario en el cliente Go.	Al tercer intento fallido, FastAPI bloquea temporalmente la cuenta por 15 minutos, deniega nuevos intentos y registra el evento con IP y hora en los logs de auditoría.
PS-02	RF-SEC-01 / C-01, C-03 (Credenciales inválidas y fuerza bruta)	Intentar registrar o actualizar la contraseña de un usuario con un valor débil o predecible (ej. 123456 o Admin2026).	Al tercer intento fallido, FastAPI bloquea temporalmente la cuenta por 15 minutos, deniega nuevos intentos y registra el evento con IP y hora en los logs de auditoría.
PS-03	RF-SEC-01 / C-02 (Credenciales compartidas / Concurrencia)	Iniciar sesión exitosamente con el Usuario A en el Equipo 1. Sin cerrar sesión, iniciar sesión con las mismas credenciales del Usuario A en el Equipo 2.	La sesión del Equipo 1 es invalidada de inmediato al generarse la nueva sesión en el Equipo 2, impidiendo el uso concurrente y compartido de la cuenta.
PS-04	RF-SEC-01 / C-02 (Credenciales compartidas / Concurrencia)	Iniciar sesión exitosamente en el cliente Go y dejar la estación de trabajo sin interactuar durante más de 10 minutos.	El cliente en Go expira la sesión localmente, purga el token activo y redirige a la pantalla de inicio de sesión exigiendo credenciales nuevas.
PS-05	RF-SEC-02 / C-04 (Acceso denegado / RBAC)	Enviar una petición HTTP directa con el token de un "Usuario Operativo" intentando consultar la bandeja de	El servidor Go intercepta la petición, verifica que el recurso no pertenece al usuario autenticado, responde con código 403

		entrada de otro colaborador o acceder a métricas de administración.	Forbidden y bloquea la operación.
PS-06	RF-SEC-03A / C-05 (Protección de contraseñas en reposo)	Realizar una consulta directa (SELECT) a la tabla de usuarios en la base de datos central.	Ninguna contraseña se muestra en texto legible; todos los campos de clave contienen hashes criptográficos con sal irreversible.
PS-07	RF-SEC-03B / C-06 (Protección en tránsito / TLS)	Realizar una captura de tráfico con Wireshark o tcpdump en el enlace inter-sede mientras se envían correos y tokens entre sedes.	Toda la información capturada (cuerpo de correo, credenciales y tokens) aparece cifrada bajo paquetes TLS sin posibilidad de lectura en texto claro.
PS-08	RF-SEC-04 / C-07 (Acceso administrativo denegado)	Intentar establecer una conexión SSH o interfaz web hacia el router OpenWrt desde una IP perteneciente a la VLAN de Usuarios u Operativa.	El router descarta los paquetes por regla de firewall perimetral y la conexión es rechazada, permitiéndose únicamente desde la VLAN 99.

Nota. Elaboración propia (2026).

9. MATRIZ DE TRAZABILIDAD ACTUALIZADA

Tabla 6

Matriz de trazabilidad actualizada de riesgos, requisitos, controles y pruebas

Riesgo Identificado	Requisito Asociado	Control Diseñado	Prueba Asociada	¿Qué se busca mitigar o garantizar?
R0-1 (Interceptación y alteración de tráfico en tránsito)	RF-SEC-03B (Cifrado en tránsito)	C-06: Canal seguro obligatorio con TLS 1.3 entre cliente Go, servidor Go y FastAPI.	PS-07	Prevenir la captura pasiva o activa de tokens y correos confidenciales en el enlace inalámbrico inter-sede.
R0-2 (Suplantación	RF-SEC-01 (Autenticación,	C-01: Política de longitud y	PS-01 PS-02	Evitar accesos no autorizados por

por contraseñas predecibles, compartidas o sesiones abandonadas)	políticas y sesiones)	complejidad para evitar contraseñas triviales. C-02: Control de sesión única y caducidad por inactividad (10 min). C-03: Bloqueo tras 3 intentos fallidos consecutivos.	PS-03 PS-04	contraseñas débiles, impedir el uso compartido simultáneo de cuentas y cerrar sesiones abandonadas en puestos de trabajo.
R0-2 (Acceso indebido a bandejas ajenas)	RF-SEC-02 (Validación de identidad y rol)	C-04: Matriz RBAC estricta y comprobación de pertenencia de buzón por petición en el backend Go.	PS-05	Garantizar que ningún usuario pueda leer, redactar o borrar correos institucionales fuera de su ámbito asignado.
R0-2 / Fuga de credenciales en base de datos	RF-SEC-03A (Protección de contraseñas en reposo)	C-05: Hash unidireccional con sal (bcrypt/Argon2) en base de datos; nunca texto plano.	PS-06	Evitar la exposición de contraseñas en caso de una filtración, volcado o acceso no autorizado a la base de datos.
R0-3 (Compromiso del plano de gestión y enrutamiento)	RF-SEC-04 (Aislamiento de gestión y OSPF)	C-07: ACLs y reglas de firewall en routers/switches limitadas a VLAN 99, con autenticación en vecinos OSPF.	PS-08	Evitar la toma de control de los routers OpenWrt y switches Cisco desde redes operativas o tráfico inalámbrico no confiable.

Nota. Elaboración propia (2026).

Repositorio: https://github.com/Slucina04060708/PROYECTO-INTEGRADOR

NOMBRES Y FIRMAS

- Santiago Alejandro Lucina Mena
- Pamela Stefania Toapanta Pila
- Camila Isabel Paucar Guaranda

